

Security Operations Center

Lab 1: how to build a Security Operations Centre

Introductions



Edoardo Gerosa

Previous employment

- Cyber security consultant @ Deloitte UK
- Vigilant Service Lead @ Deloitte AG
- Product Manager, Cyber Defence @ Swiss Re

Current employment

- Chief Information Security Officer @ Sherpany

Get in touch

- LinkedIn: [linkedin.com/in/edoardo-gerosa](https://www.linkedin.com/in/edoardo-gerosa)
- Mail: e.gerosa@outlook.com
- Follow my blog: blogonsecurity.com
- X (formerly Twitter): [@edoardogerosa](https://twitter.com/edoardogerosa)
- GitHub: github.com/netevert

Agenda

Part I	Building a Security Operations Center	1 hour
Break		15 minutes
Part II	Setting up a Security Operations Center lab	1 hour

Lecture goals

The lecture aims to achieve the following goals:

1. Provide a definition of what a Security Operations Center (SOC) is
2. Provide a high-level, albeit broad, understanding of how a SOC works
3. Provide an overview of how to set up a small SOC lab

Part I

Building a SOC

What is a SOC

Definition

A SOC is an operational unit that is tasked with:

1. Providing real-time situational awareness into the ***security status*** of a given ***information technology network***
2. Executing pre-agreed protocols and processes to contain, eradicate and recover from ***confirmed cybersecurity incidents***

Note the Italicised words: a SOC's mission is limited to performing security monitoring of an IT network and only respond in cases of confirmed cybersecurity incidents. This distinction is important as other operations center flavours exist (e.g. Network Operations Center, Emergency Operations Center etc.) each pursuing alternative missions

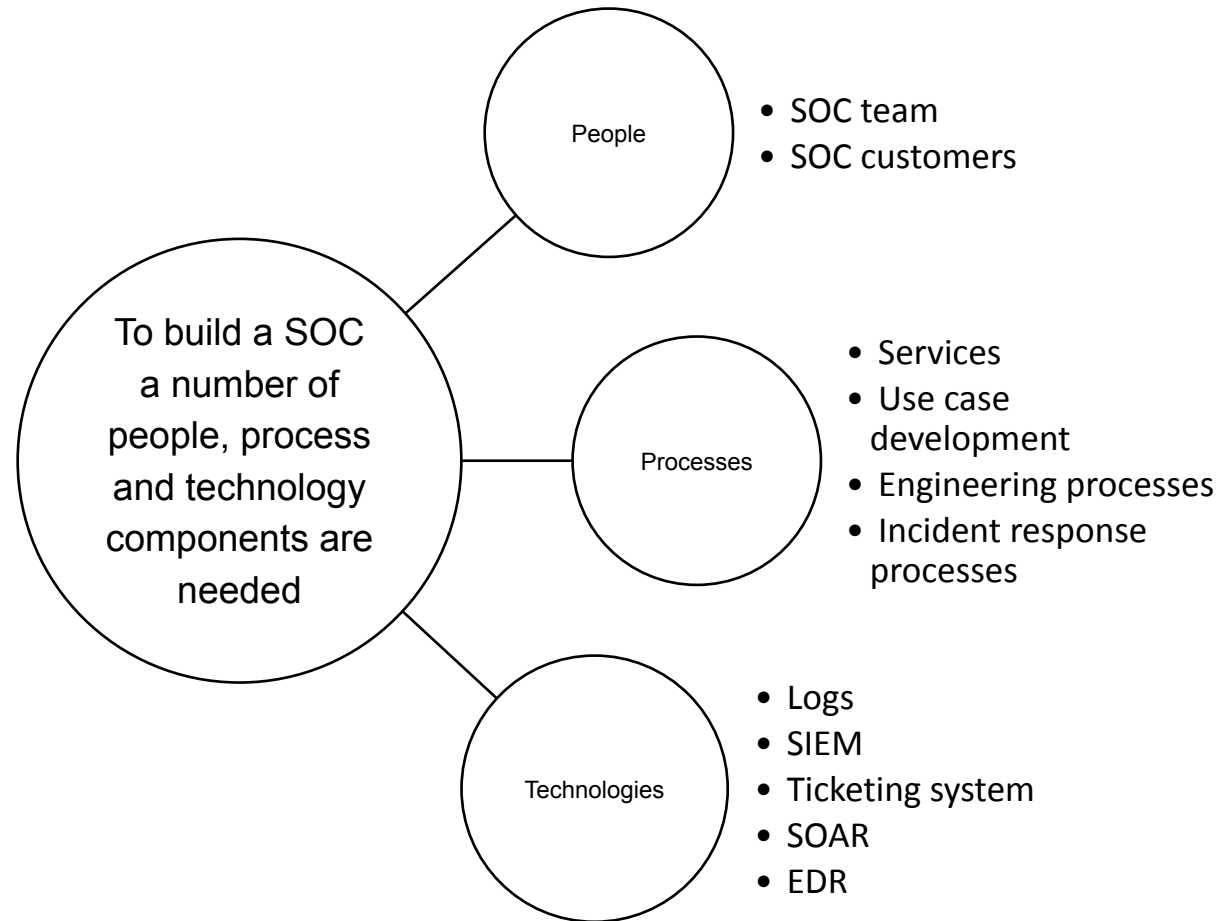


Why build a SOC

Within business organisations the creation of a SOC is typically dictated by the below business drivers:

Cybersecurity incidents	Intellectual property protection	Regulatory requirements	Third-party assessments
The occurrence of an actual cybersecurity incident is a typical business driver causing organisations to increase spending to first contain the incident and secondly monitor the organisation against future attacks	Organisations holding large amounts of sensitive intellectual property guaranteeing competitiveness in the market have a large incentive to implement IT network monitoring programs to detect both external and internal threats, typically guarding against IP theft or corporate espionage	Organisations in specific sectors, such as banking and finance, are typically placed under cybersecurity regulations in order to ensure the protection of customer data. Some regulations (i.e. NYDFS) specifically mandate the implementation of SOC's	Assessments such as penetration tests or cybersecurity maturity assessments, typically executed by third-parties, can result in findings or recommendations that kick-start the implementation of a security logging and monitoring program

How to build a SOC - Basic components



How to build a SOC - implementation phases

Depending on architectural and organisational complexity, the successful implementation of a SOC can take anywhere between 6 months to a year. The implementation of a SOC is typically executed in line with the below four phases, each leading to the execution of specific steps:

1. Planning	2. Organisational structuring	3. Process development	4. Technology deployment
• Mission, objectives and implementation strategy defined • Service requirements derived • Technology architecture designed	• Roles and responsibilities defined • Personnel hired • Managed Security Services providers contacted and Request for Proposals issued • Operating model defined	• Incident response process defined • Use case development process defined • Engineering processes defined	• SIEM provisioned and deployed • Log collection infrastructure deployed • Log collection agents deployed • Incident response technologies deployed (e.g. EDR)

Following the successful execution of the above steps a SOC can be launched into production

How to build a SOC - people

In order to operate the SOC relies, at a minimum, on two people components:

SOC team	SOC customers
Monitors IT network and executes SOC processes to protect the organisation	Consumes the SOC's cybersecurity services and is the main beneficiary of the SOC's protection processes
• Security analyst teams • Cyber engineering team • Use case developers • Team leads • SOC manager	• CSO/CIO/DPO • CISO • Legal • Compliance • Security architecture

How to build a SOC - people

The table below provides a more detailed overview of the roles and responsibilities within the SOC team:

Security analyst teams	• Depending on the maturity of the SOC multiple analyst teams can exist • Each responsible for delivering specific services (e.g. vulnerability management) • Typically divided into 3 sub-teams: level 1 monitoring, level 2 alert investigation, level 3 incident response
Cyber engineering team	• Responsible for the deployment and maintenance of the SOC's technologies • Additionally responsible for onboarding customer logs and write detection analytics
Use case developers	• Responsible for acting as the SOC's front-desk • Working with SOC customers to define monitoring use cases and fine tuning SOC services to new requirements
Team leads	• Responsible for managing the individual security analyst teams • Developing standards, policies and procedures to direct daily operations
SOC manager	• Responsible for managing the SOC • Setting strategic development priorities in line with CISO/board requirements

How to build a SOC - people

The table below provides a more detailed overview of typical SOC customers and their respective requirements:

CSO/CIO/DPO	• Rely on SOC services to guarantee the confidentiality, integrity and availability of company data or intellectual property
CISO	• Relies on SOC services to promote security awareness within organisation as well as execute specific security mandate imposed by the board
Legal	• Relies on SOC's evidence gathering and chain of custody services to support legal disputes or post-incident legal action
Compliance	• Relies on SOC compliance services to ensure the organisation remains compliant with its regulatory obligations
Security architecture	• Relies on SOC detection metrics and vulnerability management services to help security architects design robust and secure technology solutions to be used by the organisation (e.g. golden images, certified cloud resources)

How to build a SOC - processes

In order for the SOC to operate on a daily basis the below key processes should be put in place:

SOC Services	Use case development	Engineering
• Vulnerability management • Incident handling • Threat intelligence • Data breach reporting • Lost/stolen IT assets • Forensics and legal support	• Customer onboarding • Use case design • Log onboarding and analytics development • Continuous service improvement	• Access management • Change management • Continuous integration • Disaster recovery • Health monitoring

How to build a SOC - processes

The table below provides a more detailed overview of typical SOC services that have an organisation-facing focus:

Incident handling *	• Monitoring, detecting, contain, eradicate and recover cybersecurity incidents
Vulnerability management	• Identifying, classifying, prioritizing, remediating, and mitigating software vulnerabilities
Threat intelligence	• Gathering and internally circulating information about threats and threat actors that might cause harmful events against the organisation
Data breach reporting	• Containing, eradicating and recovering incidents involving customer data in line with regulatory requirements
Lost/stolen IT assets	• Reporting loss or theft of assets (i.e. employee laptops) that may contain sensitive information or intellectual property
Forensics and legal support	• Providing forensic evidence gathering and chain of custody support to ongoing investigations or legal proceedings

* Covered in more detail within slides 17-21

How to build a SOC - processes

The table below provides a more detailed overview of typical SOC services that have a customer (i.e. cloud application owners or IT domain owners) focus:

Customer onboarding	• Contacting prospective customers internally within the organisation, introducing them to the SOC and outlining the overall onboarding process
Use case design	• Defining with customers the set of use cases to be implemented to monitor their application or IT asset
Log onboarding and analytics development	• Connecting log sources to the relevant SOC log collection technologies and developing the necessary analytics rules to detect suspicious behaviours
Continuous service improvement	• Continuously improving the SOC customer facing processes to ensure that only high-fidelity use cases are implemented and that low-fidelity, low-value use cases are retired as soon as possible

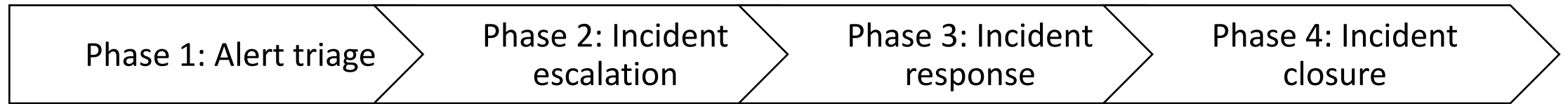
How to build a SOC - processes

The table below provides a more detailed overview of typical engineering services that aim to sustain the SOC technologies that enable delivery of SOC and use case development services:

Access management	• Provision and closely manage team access to SOC technologies according to "least privilege" or "need to know" principles
Change management	• Receive, review, approve and manage configuration changes to SOC technologies while guaranteeing alignment and awareness on said changes across SOC teams
Continuous integration	• Upgrade and redeploy configuration changes to SOC technologies in a manner that causes minimal disruption to daily operations
Disaster recovery	• Ensure that SOC technologies (whether on premise or cloud hosted) can be quickly recovered in case of disruption or system failures
Health monitoring	• Ensure that SOC technologies continue to correctly receive log data and operate in a "nominal" state

How to build a SOC - incident handling

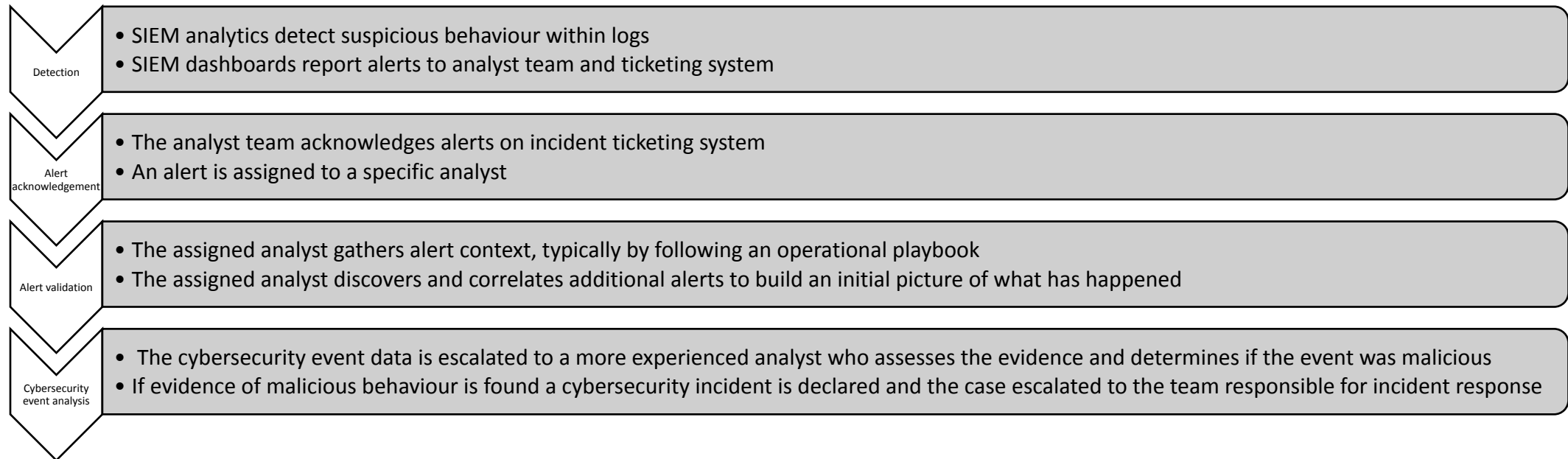
The SOC's incident handling process is the central procedure at the heart of the SOC's services. It ensures that the SOC has a structured approach to triaging alerts, identify cybersecurity incidents and respond accordingly. The incident handling process is typically structured in line with the below phases:



Incident handling – alert triage

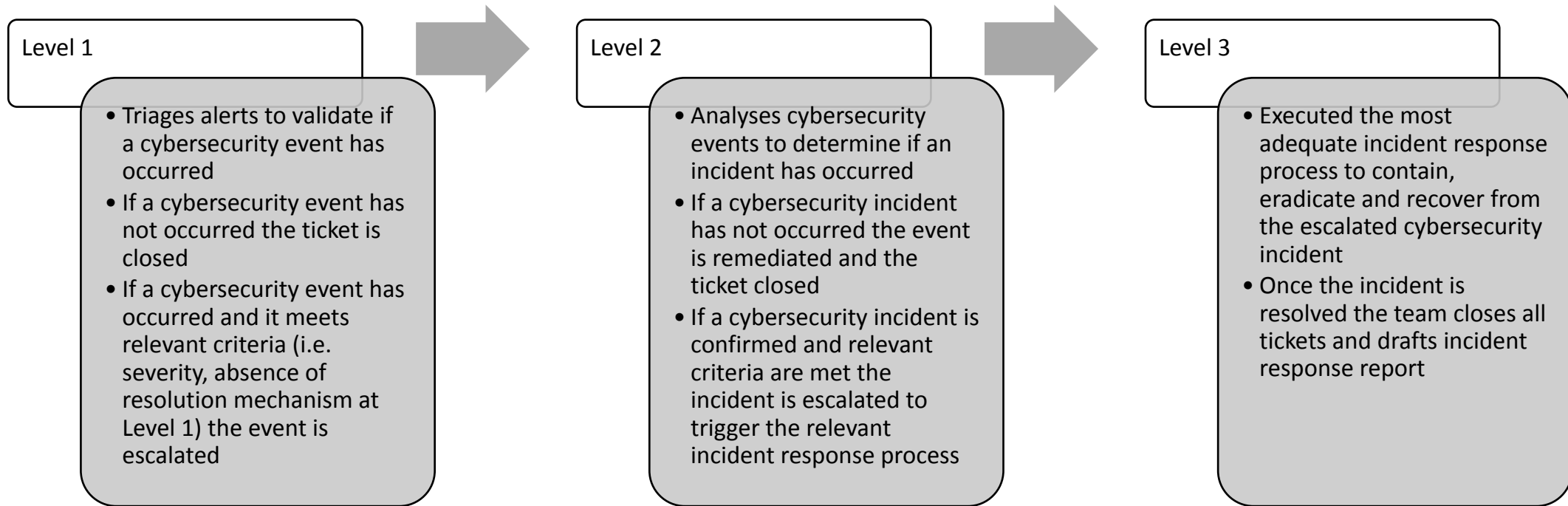
The alert triage process is designed to validate whether alerts raised by the SIEM constitute:

- a) An event of a cybersecurity nature
- b) An event of a malicious nature or, alternatively, a cybersecurity event



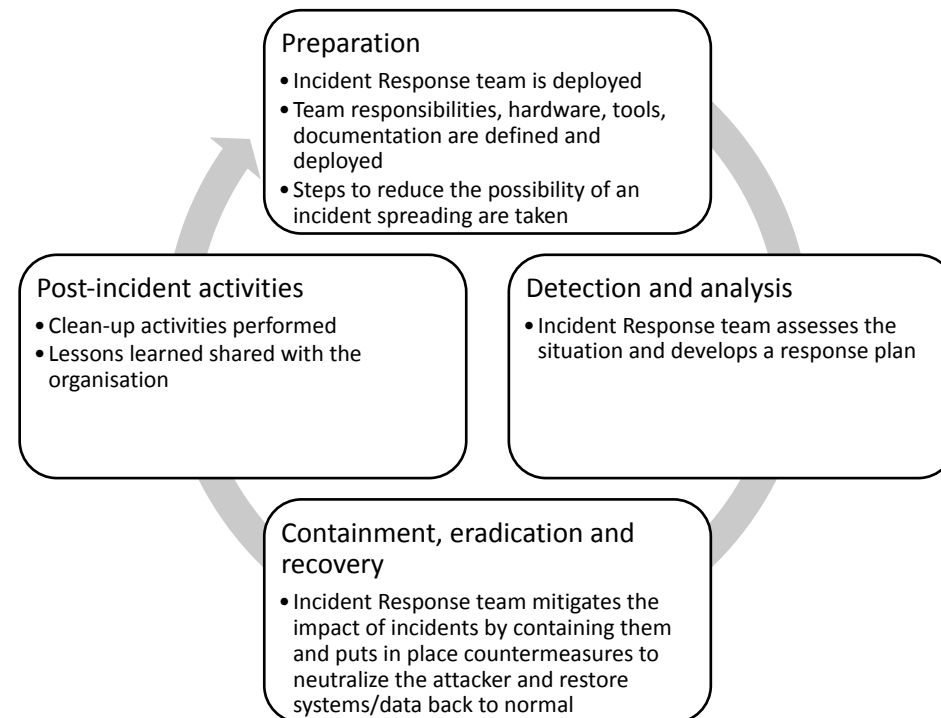
Incident handling – incident escalation

Escalation processes are critical for the functioning of the SOC as they determine the criteria to forward cybersecurity events to the team with the most appropriate skillset to resolve them. A typical SOC escalation pattern is outlined in the table below:



Incident handling – incident response

The incident response process is the process that matter most across all SOC operations. Through its incident response process the SOC fulfils its mission to detect and respond to malicious cybersecurity activity. One of the most established incident response standard has been developed by the National Institute of Standard and Technology (NIST) in its *Computer Security Incident Handling Guide* ([special publication 800-61 revision 2](#))



Incident handling – incident closure

Incident closure processes aim to:

1. Ensure adequate records of the incident are retained within ticketing systems
2. That all incidents tickets are closed and monitoring systems are brought back to a nominal state
3. That lessons learned are captured within an incident response report and shared within the organisation

Key lessons learned to be captured as part of the post-incident assessment typically include:

Assessing effectiveness of incident response process	Reviewing logs, forms, reports, and other incident documentation for adherence to established incident response policies and procedures
Assessing effectiveness of detection mechanisms	Identifying which precursors and indicators of the incident were recorded to determine how effectively the incident was logged and identified
Damage assessment	Calculating the estimated monetary damage from the incident(e.g., information and critical business processes negatively affected by the incident)
Threat assessment	Determining if the actual cause of the incident was identified, and identifying the vector of attack, the vulnerabilities exploited, and the characteristics of the targeted or victimized systems, networks, and applications
Next steps	Identifying which measures, if any, could have prevented the incident

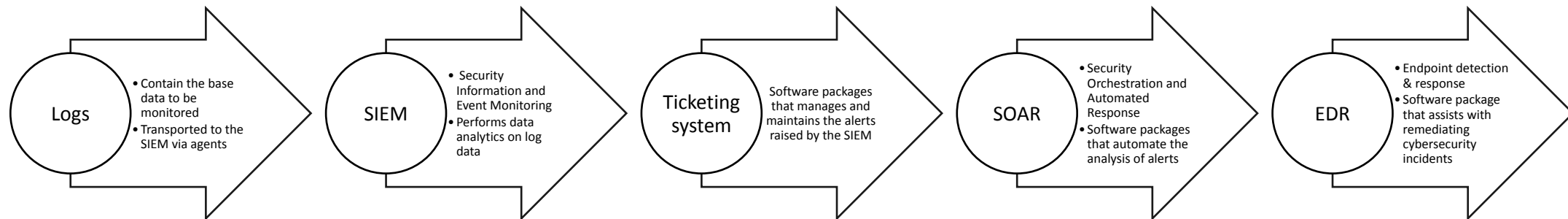
How to build a SOC - performance management

A SOC should have processes in place to constantly assess its performance and output. To this end a SOC should implement processes to measure Key Performance Indicators (KPIs) as well as Service Level Objectives (SLOs). Each fulfil a specific function as outlined in the table below:

Measurement	KPIs	SLOs
Objective	Measures performance of SOC	Measures outputs of SOC
Examples	• Number of incident handled • Mean time to respond • Time to detect • Time to validate • Losses accrued vs losses prevented	• Incident response SLOs by incident severity • Ticket acknowledgement SLOs • Ticket closure SLOs • Incident reporting SLOs

How to build a SOC - technologies

A SOC relies on a number of technologies to sustain its key processes and enable the delivery of security services. The key technologies that a SOC must employ are outlined below:



SOC technologies - logs

Definition

"At the heart of log data are, simply, log messages, or logs. A log message is what a computer system, device, software etc. Generates in response to some sort of stimuli. What exactly the stimuli are greatly depends on the source of the log message."

[Logging and Log Management, 2013, Syngress](#)

Five types of log messages exist:

- Informational
- Debug
- Warning
- Error
- Alert



Screenshot of Windows security auditing log record

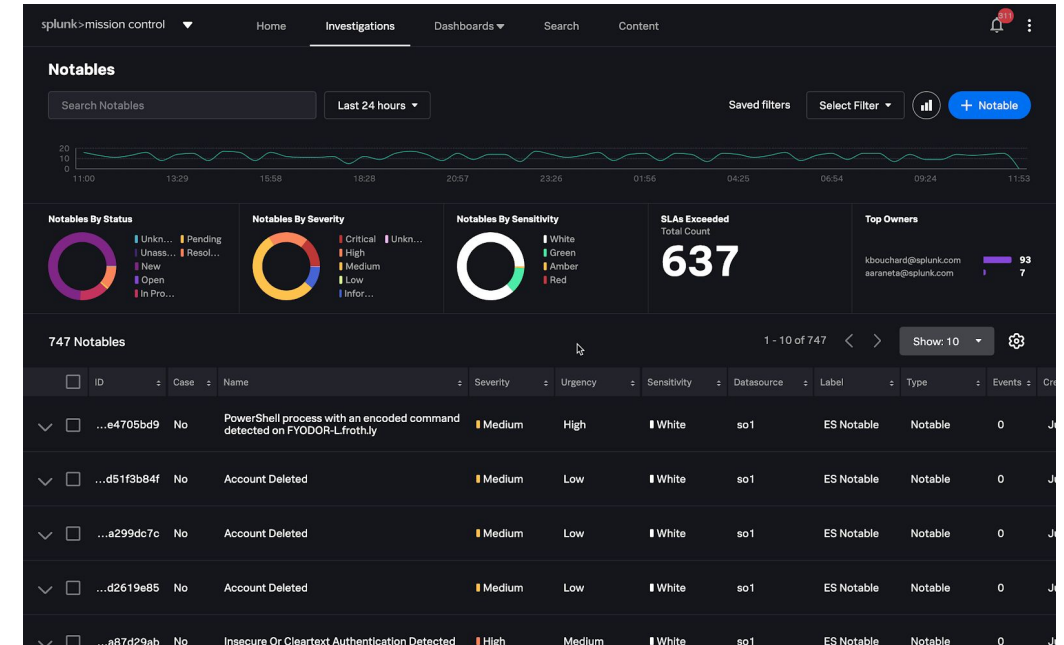
SOC technologies - SIEM

Security Information & Event Management

Definition

"A system that can consume events from hundreds of different types of devices and systems and then build rules around those events ... today a SOC that operates without some kind of SIEM tool is seriously handicapped"

[Designing and Building a Security Operations Center, D. Nathans, 2015, Syngress](#)

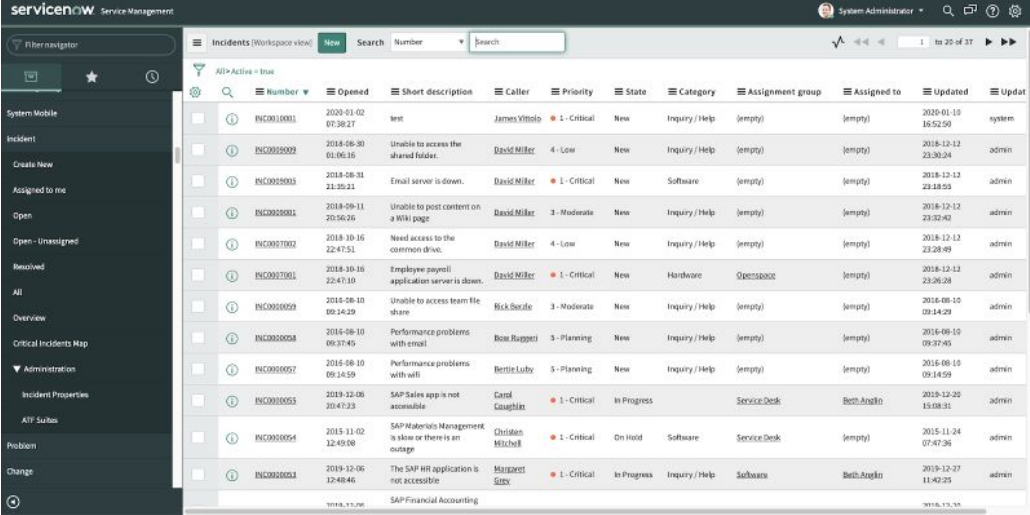


Screenshot of Splunk's SIEM software

SOC technologies – ticketing system

Definition

At their heart ticketing systems are software packages that assist a SOC with managing and maintaining the alerts raised by the SIEM. In a SOC context however ticketing systems act as repositories of evidence collected for any given cybersecurity event/incident as well as evidence of actions taken by the SOC in responding to said cybersecurity events/incidents.



The screenshot displays the ServiceNow 'Incidents' workspace. The interface includes a left-hand navigation menu with options like 'System Mobile', 'Incident', 'Create New', 'Assigned to me', 'Open', 'Open - Unassigned', 'Resolved', 'All', 'Overview', 'Critical Incidents Map', 'Administration', 'Incident Properties', 'ATF Suites', 'Problem', and 'Change'. The main area shows a table of incidents with columns for Number, Opened, Short description, Caller, Priority, State, Category, Assignment group, Assigned to, Updated, and Updated by. The table lists various incidents, including those related to email server issues, network connectivity, and application performance.

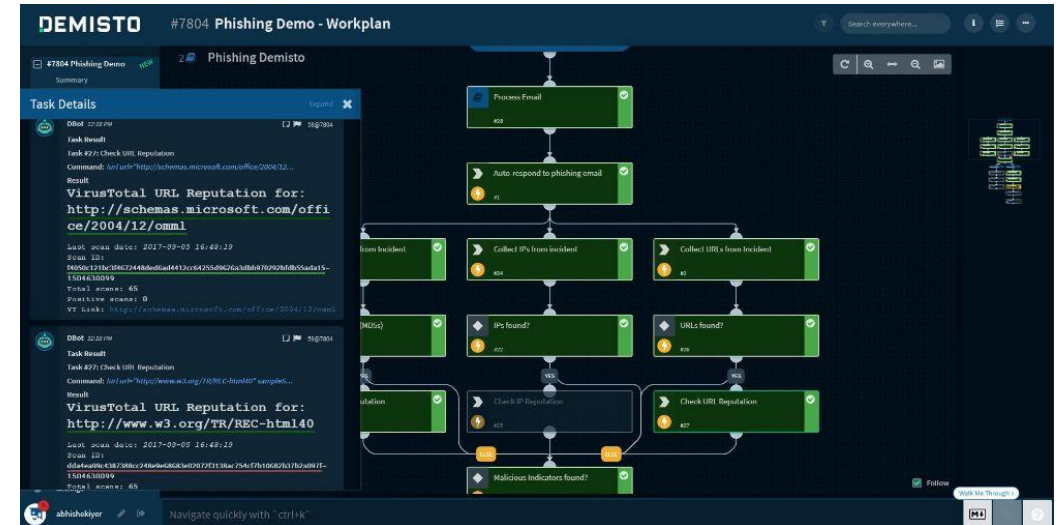
Number	Opened	Short description	Caller	Priority	State	Category	Assignment group	Assigned to	Updated	Updated by
INC0010001	2020-01-02 07:30:27	test	James Vitello	1 - Critical	New	Inquiry / Help	(empty)	(empty)	2020-01-02 16:52:50	system
INC0010002	2018-08-30 01:06:16	Unable to access the shared folder.	David Miller	4 - Low	New	Inquiry / Help	(empty)	(empty)	2018-12-12 23:30:24	admin
INC0010003	2018-08-31 21:35:21	Email server is down.	David Miller	1 - Critical	New	Software	(empty)	(empty)	2018-12-12 23:18:55	admin
INC0010004	2018-09-11 20:56:26	Unable to post content on a Wiki page	David Miller	3 - Moderate	New	Inquiry / Help	(empty)	(empty)	2018-12-12 23:32:40	admin
INC0010005	2018-10-16 22:47:51	Need access to the common drive.	David Miller	4 - Low	New	Inquiry / Help	(empty)	(empty)	2018-12-12 23:28:49	admin
INC0010006	2018-10-16 22:47:10	Employee payroll application server is down.	David Miller	1 - Critical	New	Hardware	Operations	(empty)	2018-12-12 23:26:28	admin
INC0010007	2016-08-10 09:14:29	Unable to access team file share	Rick Bortle	3 - Moderate	New	Inquiry / Help	(empty)	(empty)	2016-08-10 09:14:29	admin
INC0010008	2016-08-10 09:37:45	Performance problems with email	Bon Ruggieri	3 - Planning	New	Inquiry / Help	(empty)	(empty)	2016-08-10 09:37:45	admin
INC0010009	2016-08-10 09:14:59	Performance problems with web	Bertie Luby	3 - Planning	New	Inquiry / Help	(empty)	(empty)	2016-08-10 09:14:59	admin
INC0010010	2019-12-08 20:47:23	SAP Sales app is not accessible	Carol Goughlin	1 - Critical	In Progress	Service Desk	Service Desk	Beth Anglin	2019-12-20 15:08:31	admin
INC0010011	2015-11-02 12:45:06	SAP Materials Management is slow or there is an outage	Christian Mitchell	1 - Critical	On Hold	Software	Service Desk	(empty)	2015-11-24 07:47:36	admin
INC0010012	2019-12-06 12:48:46	The SAP HR application is not accessible	MATTHEW GUY	1 - Critical	In Progress	Inquiry / Help	Software	Beth Anglin	2019-12-27 11:42:25	admin
INC0010013		SAP Financial Accounting								

Screenshot of ServiceNow ticketing software

SOC technologies - SOAR

Definition

Security Orchestration and Automated Response platforms are software packages that assist a SOC with automating the analysis of alerts. They act as a force multiplier for daily SOC operations by automating all manually intensive tasks (i.e. sending emails, enriching alert data) and freeing up analyst time to concentrate on the core of their job: analysing cybersecurity events to determine if something malicious has happened

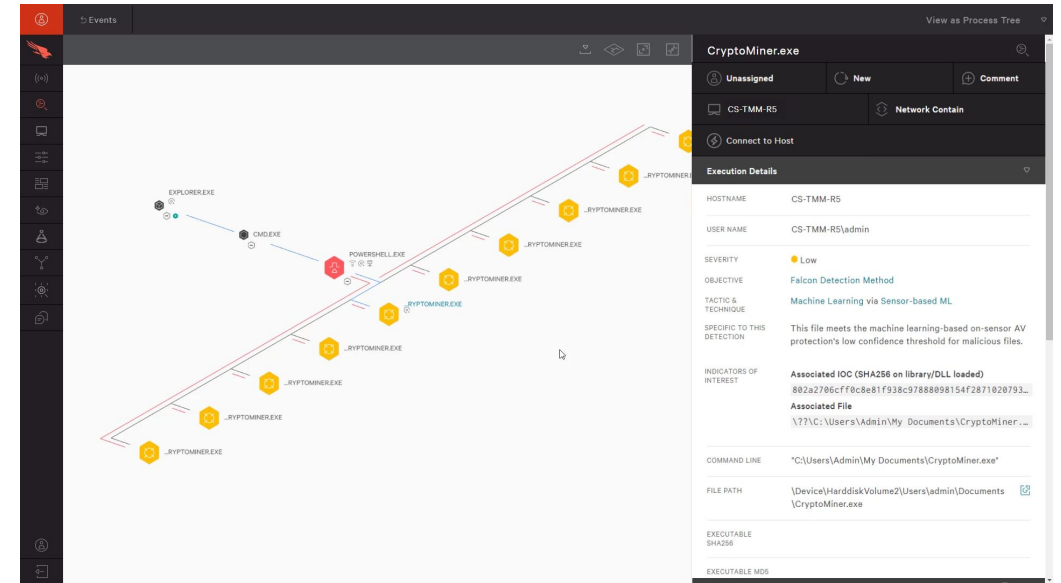


Screenshot of Demisto SOAR software

SOC technologies - EDR

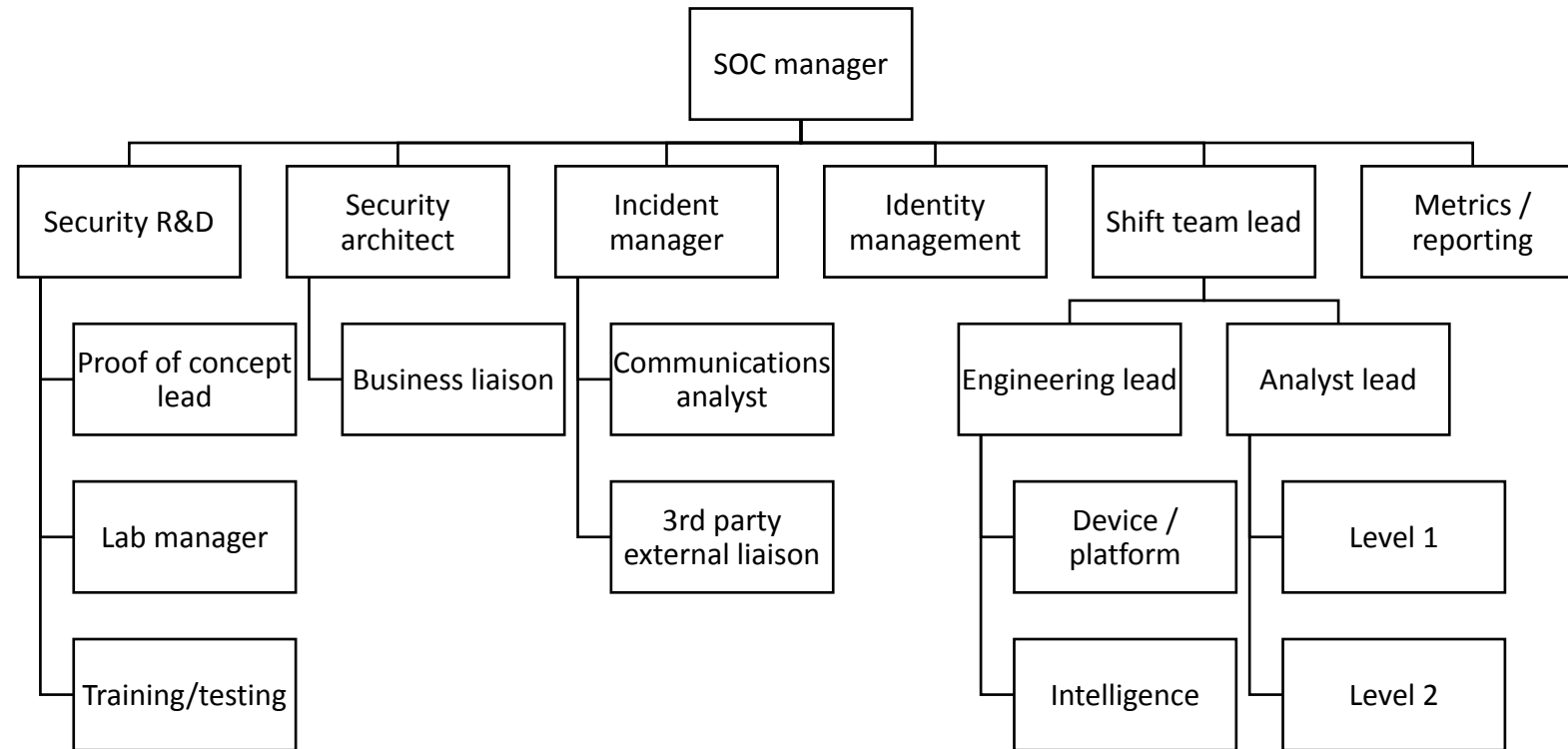
Definition

Endpoint Detection and Response tools are software packages that assist a SOC with mitigating or remediating cybersecurity incidents. EDR tools are typically installed on a central server and are connected to all devices in an organisation via agents. In this way SOC operators in case of an incident can connect directly to any company devices through the EDR tools to respond to a confirmed cybersecurity incident.



Screenshot of CrowdStrike Falcon EDR software

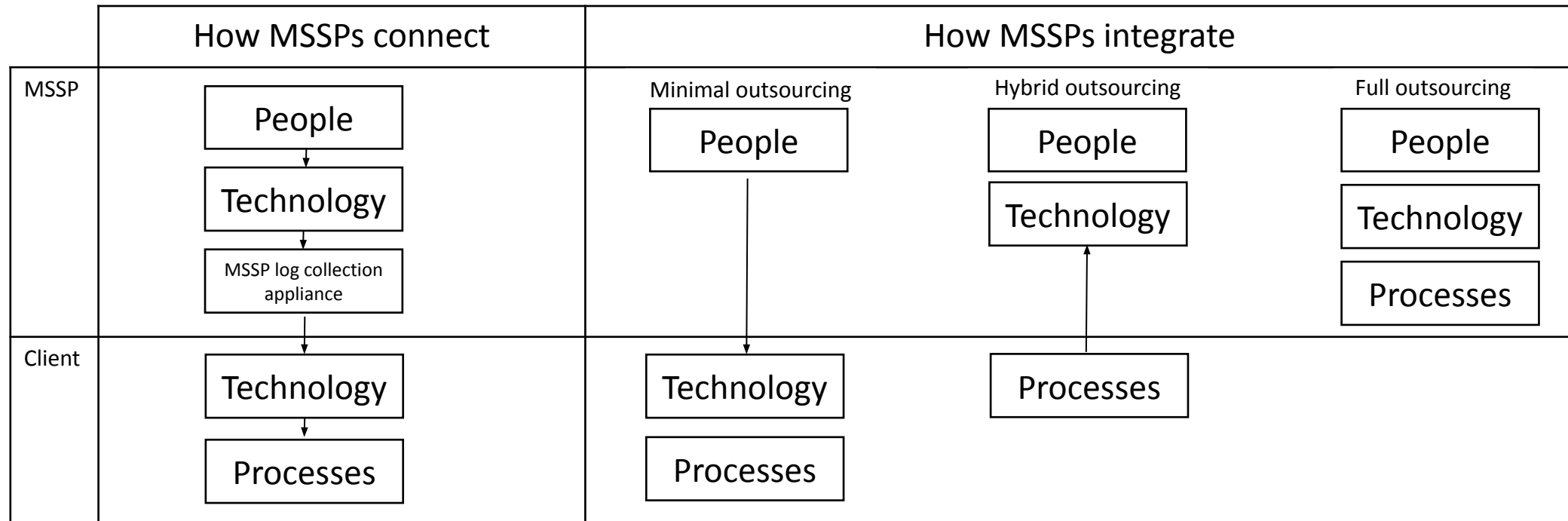
How to build a SOC - structure



Example of a larger SOC organizational structure taken from page 94, **Designing and Building a Security Operations Center**, D. Nathans, 2015, Syngress

How to build a SOC - outsourcing

SOCs do not always need to be built in-house. For most organisations it is faster and more cost effective to outsource security operations to a Managed Security Services Provider. For a fixed, predictable yearly fee an organisation can delegate the implementation and operational management of security operations to a third party. The table below provides an overview of how MSSP connect and integrate with customers in order to provide their security services:



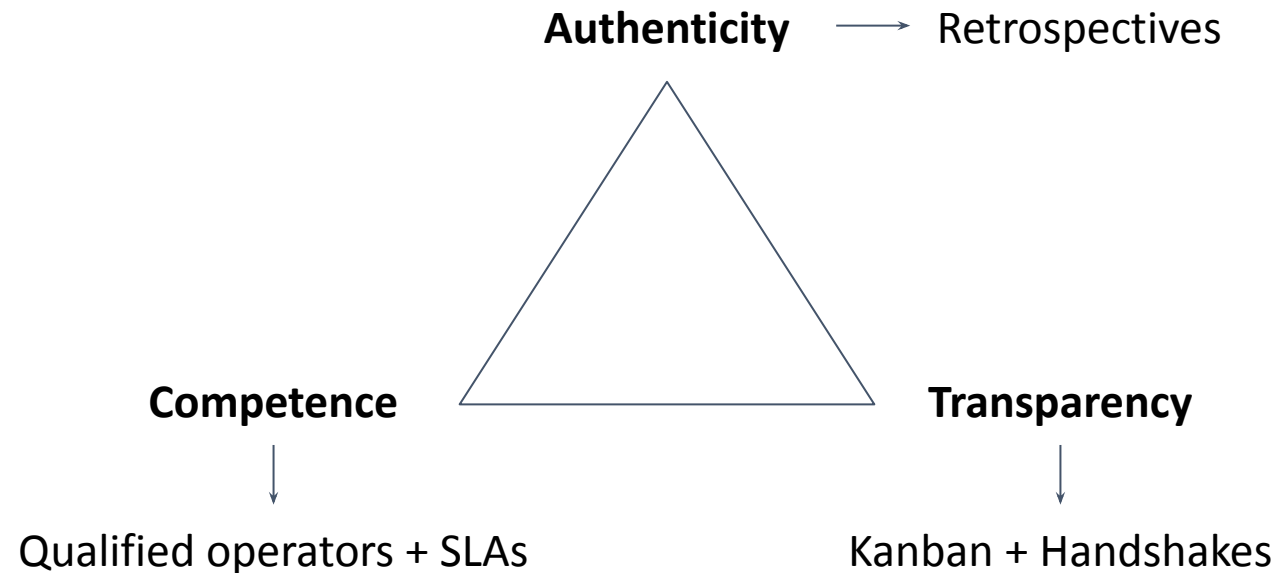
How to build a SOC - culture

Building a high performance culture in a SOC is critical to foster an environment of excellence and continuous improvement. In a SOC (and in any industry, for that matter) a high performance culture is built on a foundation of trust. There are several frameworks describing the key ingredients to build trust. However, in an operational environment, most of these ingredients can be summarised down to three factors:



How to build a SOC - culture building

Authenticity, competence and transparency represent agreeable, yet aspirational concepts. Applying them successfully in an operational concept requires a number of project management and trust building techniques. Below you can find a (non exhaustive) overview of some of the project management and trust building techniques being used in SOC today:



Break

15 minutes

Part II

Setting up a SOC lab

Requirements

In order to emulate a SOC as close as is realistically possible our lab needs should fulfil the below requirements:

- Be easily deployable and destroyable
- Be cost effective
- Include a small network of virtual machines
- Include a SIEM
- Has log collection for virtual machine processes and events enabled and connected to the SIEM
- Log collection configured to detect publicly know adversary tactics, techniques and procedures

Lab set up – deployment environment

There are two options available when it comes to deploying our SOC lab environment:

	Cloud	On-premise
Advantages	• No infrastructure cost • Infrastructure as code (IaC) framework available out of the box • Easy to deploy security tooling (if available out of the box)	• You can use your laptop/server • One-off cost and low maintenance costs • You can pick a single IaC and deployment configuration tool and apply it across different technologies
Disadvantages	• Not free and costs compound quickly • Need to learn IaC frameworks and cloud infrastructure from scratch - moreover these can be different across cloud providers	• You need to install IaC and post-deployment configuration tools on your machine • Deploying security tooling is comparatively harder unless you automate your deployments

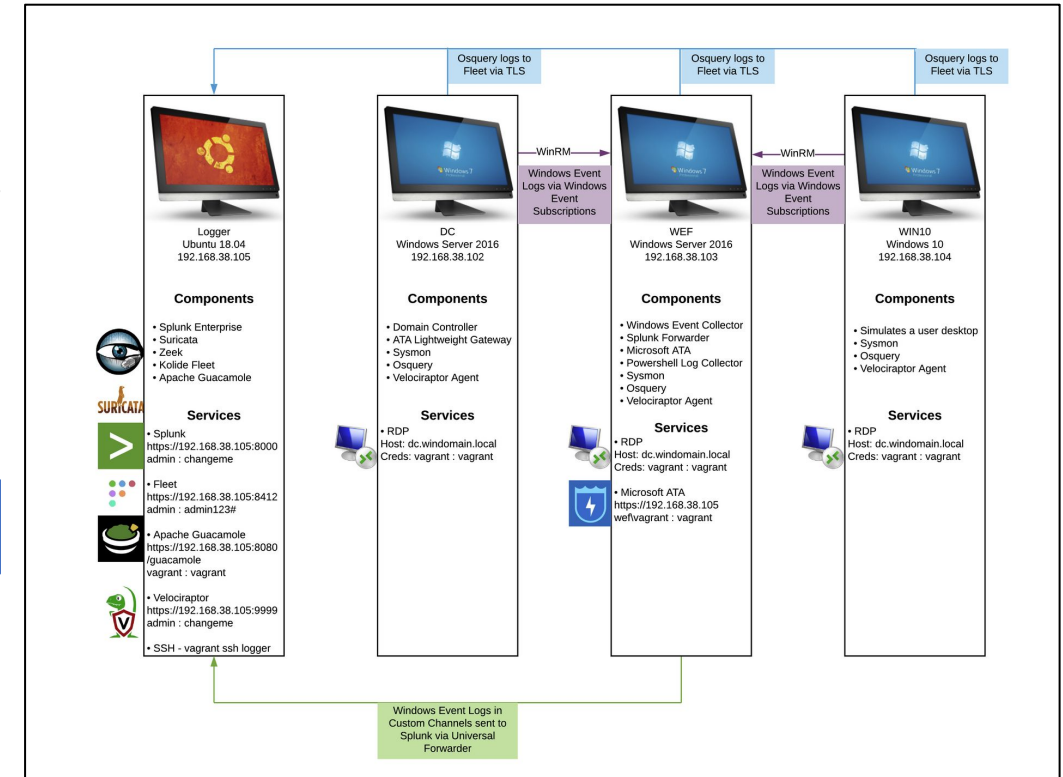
Lab set up – laptop option

DetectionLab

From [Chris Long's GitHub README](#):

"(DetectionLab) has been designed with defenders in mind. Its primary purpose is to allow the user to quickly build a Windows domain that comes pre-loaded with security tooling and some best practices when it comes to system logging configurations"

As of 2023 DetectionLab is no longer being actively maintained



Screenshot of Chris Long's DetectionLab topology

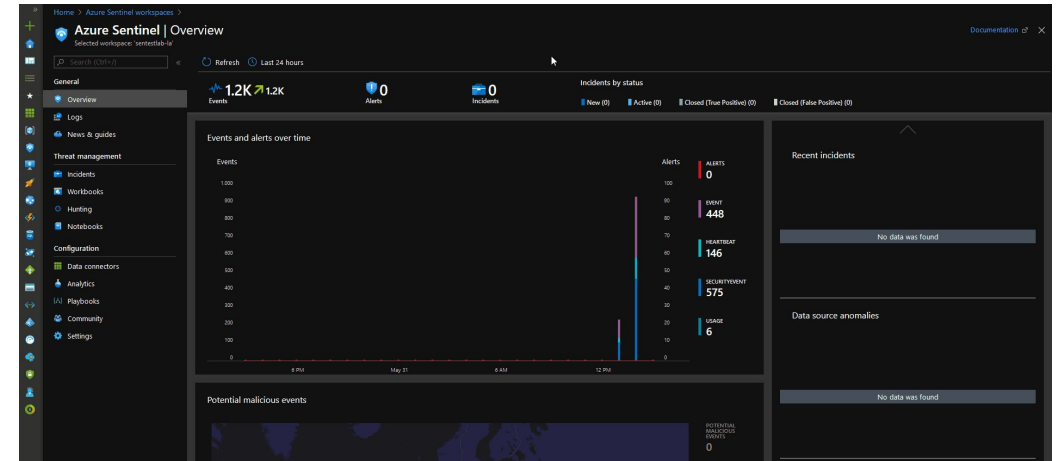
Lab set up – cloud option

Given the maturity of the DetectionLab project, this would have always be the preferred option when deploying a SOC test lab. However, today, there are better options that solely leverage cloud based security monitoring technologies:

Sentinel-ATT&CK

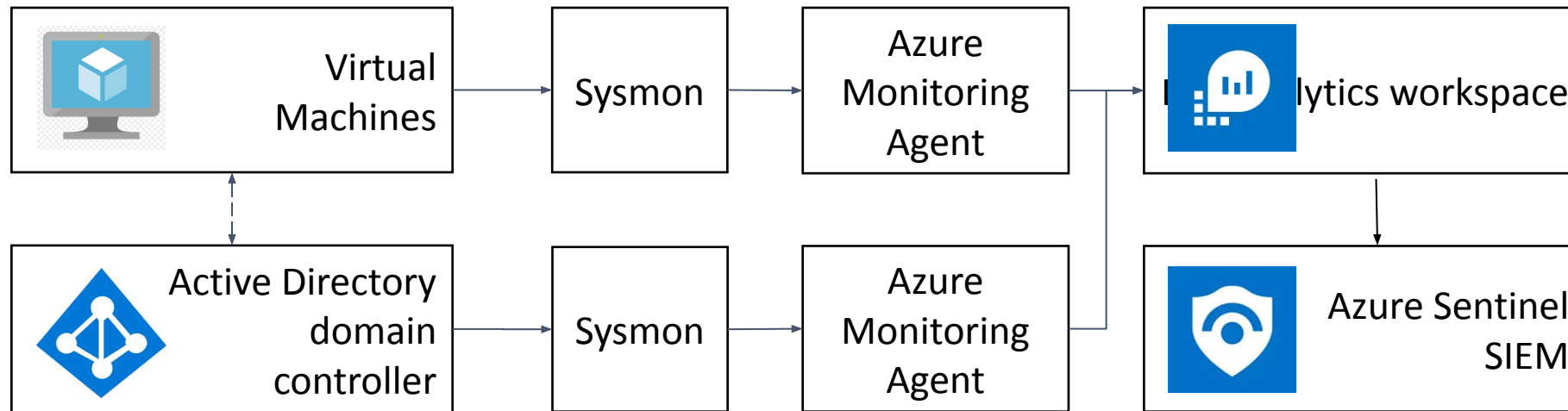
From the [project README](#):

"Sentinel ATT&CK aims to simplify the rapid deployment of a threat hunting capability that leverages Sysmon and MITRE ATT&CK on Azure Sentinel."



Screenshot of Sentinel-ATT&CK's Sysmon monitoring workbook

Lab set up – network infrastructure overview



We will use Infrastructure as Code technology to automate the deployment of our lab

Lab network infrastructure – Infrastructure as code

Definition

From [Microsoft Azure's DevOps resource center](#):

"Infrastructure as Code (IaC) is the management of infrastructure (networks, virtual machines, load balancers, and connection topology) in a descriptive model, using the same versioning as DevOps team uses for source code. Like the principle that the same source code generates the same binary, an IaC model generates the same environment every time it is applied. IaC is a key DevOps practice and is used in conjunction with continuous delivery"

Characteristics:

- Based on **idempotency**, meaning a deployment command always sets the target environment into the same configuration
- Based on machine readable **configuration files**, preventing environment drift
- Avoids manual configurations and enforces **deployment consistency**

Lab network infrastructure – Infrastructure as Code

A number of infrastructure as code tools exist that can help us automate the deployment of our lab. The table below provides an overview of options and their respective advantages and disadvantages:

Tool	 Azure Bicep	 Terraform	 Ansible
Advantages	• Azure native IaC framework • Well documented • Smoke testing • Excellent rollback	• Intuitive configuration language • Modular design • Excellent state maintenance	• Intuitive configuration language • Simple to learn • No dependency on agents
Disadvantages	• The underlying configuration ARM files are hard to read and JSON based • Limited post-deployment configuration capabilities	• Always in development • Not a native Azure IaC framework • No error handling or rollback	• YAML based • Not an infrastructure deployment framework • Windows poorly supported

Lab network infrastructure – Infrastructure as code

We will use Bicep as our Infrastructure as Code solution. Our configuration package will comprise:

- A main configuration file containing the lab deployment script
- Module files to automate the deployment of virtual machines and Sentinel
- A variables configuration file where we can manage all lab configuration items and credentials

Only two commands are needed:

1. Deploy lab:

```
az deployment group create --resource-group hsl --template-file main.bicep --parameters 'main.parameters.json'
```

2. Destroy lab:

```
az group delete --name hsl
```

Lab detection infrastructure

Our detection infrastructure will make use of two simple ingredients:

1. **Sysmon** to detect suspicious processes
2. **Azure Sentinel** to report and process suspicious processes

Both are two highly mature technologies from Microsoft that, in combination, can be used to rapidly deploy an effective detection and threat hunting capability that presents the following characteristics:

- a. Is endpoint based: endpoints are often used as an entry point into a network
- b. Is cheap: EDR tools are great, but often quite costly
- c. Can leverage adversarial frameworks (such as MITRE ATT&CK) to structure your detection rules or hunts
- d. Is fast to deploy: EDR tools cannot be rapidly deployed as fast as Azure native security tooling

Lab detection infrastructure – Sysmon overview

- [Sysmon](#) is a free, powerful host-level tracing tool, developed by a small team of Microsoft employees
- Initially developed for internal use at Microsoft
- Sysmon uses a device driver and a service that runs in the background and loads early in the boot process
- Monitors more than 20 events ranging from process creation, file timestamp changes, network connections, registry events and DNS events

Sysmon v10.2

06/28/2019 • 13 minutes to read • 

By Mark Russinovich and Thomas Garnier

Published: June 28, 2019



[Download Sysmon \(1.4 MB\)](#)

Lab detection infrastructure – Sysmon overview

- Sysmon must be installed on every endpoint we plan to monitor
- An XML configuration file is used to configure Sysmon to collect or discard specific data
- Data is excluded or included by filtering **Events** (e.g. ProcessCreate, ImageLoad) using **Filters** (e.g. conditionals, search parameters)
- The configuration file is easily installed with the command:
Sysmon -c sysmon_config_filename.xml

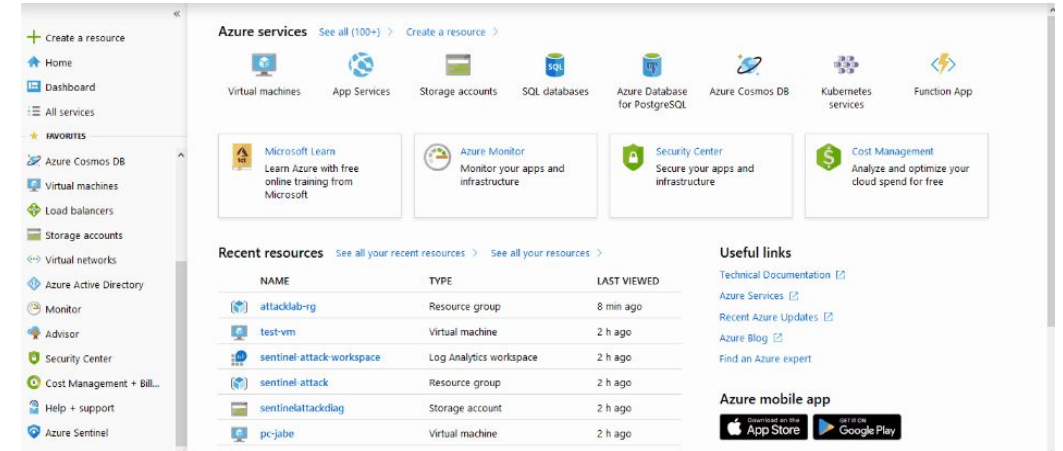
```
63 <Sysmon schemaversion="4.50">
64   <!--SYSMON META CONFIG-->
65   <HashAlgorithms>md5,sha256,IMPHASH/HashAlgorithms> <!-- Both MD5 and SHA256 are the industry-standard algorithms. Remove IMPHASH if you do not use DLL import finger
66   <CheckRevocation/> <!-- Check loaded drivers, log if their code-signing certificate has been revoked, in case malware stole one to sign a kernel driver -->
67
68   <!-- <ImageLoad/> --> <!-- Would manually force-on ImageLoad monitoring, even without configuration below. Included only documentation. -->
69   <!-- <ProcessAccessConfig/> --> <!-- Would manually force-on ProcessAccess monitoring, even without configuration below. Included only documentation. -->
70   <!-- <PipeMonitoringConfig/> --> <!-- Would manually force-on PipeCreated / PipeConnected events, even without configuration below. Included only documentation. -->
71   <!-- <ArchiveDirectory/> -->
72
73   <EventFiltering>
74
75   <!--SYSMON EVENT ID 1 : PROCESS CREATION [ProcessCreate]-->
76   <!--COMMENT: All processes launched will be logged, except for what matches a rule below. It's best to be as specific as possible,
77   to avoid user-mode executables imitating other process names to avoid logging, or if malware drops files in an existing directory.
78   Ultimately, you must weigh CPU time checking many detailed rules, against the risk of malware exploiting the blindness created.
79   Beware of Masquerading, where attackers imitate the names and paths of legitimate tools. Ideally, you'd use both file path and
80   code signatures to validate, but Sysmon does not support that. Look into AppLocker/WindowsDeviceGuard for whitelisting support. -->
81
82   <!--DATA: UtcTime, ProcessGuid, ProcessID, Image, FileVersion, Description, Product, Company, CommandLine, CurrentDirectory, User, LogonGuid, LogonId, Termin
83   <RuleGroup name="" groupRelation="or">
84     <ProcessCreate onmatch="exclude">
85       <!--SECTION: Microsoft Windows-->
86       <CommandLine condition="begin with">"C:\Windows\system32\wermgr.exe" "-queueReporting_svc" </CommandLine> <!--Windows:Windows error reporting/teleme
87       <CommandLine condition="begin with">"C:\Windows\system32\DllHost.exe /Processid/<CommandLine> <!--Windows-->
88       <CommandLine condition="begin with">"C:\Windows\system32\wbem\wmiprvse.exe -Embedding/<CommandLine> <!--Windows: WMI provider host-->
89       <CommandLine condition="begin with">"C:\Windows\system32\wbem\wmiprvse.exe -secured -Embedding/<CommandLine> <!--Windows: WMI provider host-->
90       <CommandLine condition="is">"C:\Windows\system32\wermgr.exe -upload/<CommandLine> <!--Windows:Windows error reporting/telemetry-->
91       <CommandLine condition="is">"C:\Windows\system32\SearchIndexer.exe /Embedding/<CommandLine> <!--Windows: Search Indexer-->
92       <CommandLine condition="is">"C:\Windows\system32\wermgr.exe -queueReporting/<CommandLine> <!--Windows:Windows error reporting/telemetry-->
93       <CommandLine condition="is">">\\?\C:\Windows\system32\autochk.exe *"/<CommandLine> <!--Microsoft:Startup: Auto Check Utility-->
94       <CommandLine condition="is">"SystemRoot\System32\smss.exe/<CommandLine> <!--Microsoft:Startup: Windows Session Manager-->
95       <CommandLine condition="is">"C:\Windows\System32\RuntimeBroker.exe -Embedding/<CommandLine> <!--Windows:Apps permissions [ https://fosshbytes.com/runti
96       <Image condition="is">"C:\Program Files (x86)\Common Files\Microsoft shared\ink\TabTip32.exe/<Image> <!--Windows: Touch Keyboard and Handwriting Panel
97       <Image condition="is">"C:\Windows\System32\TokenBrokerCookies.exe/<Image> <!--Windows: SSO sign-in assistant for MicrosoftOnline.com-->
98       <Image condition="is">"C:\Windows\System32\plasmv.exe/<Image> <!--Windows: Performance Logs and Alerts DCOM Server-->
99       <Image condition="is">"C:\Windows\System32\wifitask.exe/<Image> <!--Windows: Wireless Background Task-->
100      <Image condition="is">"C:\Windows\system32\CompatTelRunner.exe/<Image> <!--Windows: Customer Experience Improvement-->
101      <Image condition="is">"C:\Windows\system32\PrintIsolationHost.exe/<Image> <!--Windows: Printing-->
102      <Image condition="is">"C:\Windows\system32\SppExtComObj.Exe/<Image> <!--Windows: RMS activation-->
103      <Image condition="is">"C:\Windows\system32\audiiodg.exe/<Image> <!--Windows: Launched constantly-->
104      <Image condition="is">"C:\Windows\system32\conhost.exe/<Image> <!--Windows: Command line interface host process-->
105      <Image condition="is">"C:\Windows\system32\mobsync.exe/<Image> <!--Windows: Network file syncing-->
106      <Image condition="is">"C:\Windows\system32\musnotificatn.exe/<Image> <!--Windows: Update pop-ups-->
107      <Image condition="is">"C:\Windows\system32\mustotification.exe/<Image> <!--Windows: Update pop-ups-->
108      <Image condition="is">"C:\Windows\system32\powercfg.exe/<Image> <!--Microsoft:Power: configuration management-->
```

Screenshot of SwiftOnSecurity's Sysmon configuration file

Lab detection infrastructure – Azure Sentinel

Azure Sentinel is Microsoft Azure's native SIEM platform. It packages together numerous Azure tools to build a platform that enables analysts to:

- Collect data in the Azure cloud at scale
- Write analytics to detect threats using a query language
- Investigate threats and hunt for suspicious activities
- Respond to incidents by using in-built SOAR tools



Screenshot of Azure Sentinel being deployed

Lab detection infrastructure – Azure Sentinel

Azure Sentinel contains a number of excellent features:

1. An easy-to-use query language
 - Kusto Query Language (KQL)
 - Read only
 - Used to access and query log analytics workspaces via API or Web App
2. Incident grouping
 - Grouping over time periods (default 24h)
 - Incident grouping by case with Sentinel Fusion to reduce alert fatigue
 - Ability to bake your own organisation's machine learning models
3. Threat response automation with Logic Apps
 - Large amount of connectors (SNOW, Jira, Outlook, AD etc.)
 - Ability to develop custom connectors
 - Easy to use playbook designer

Lab detection infrastructure – Azure Sentinel

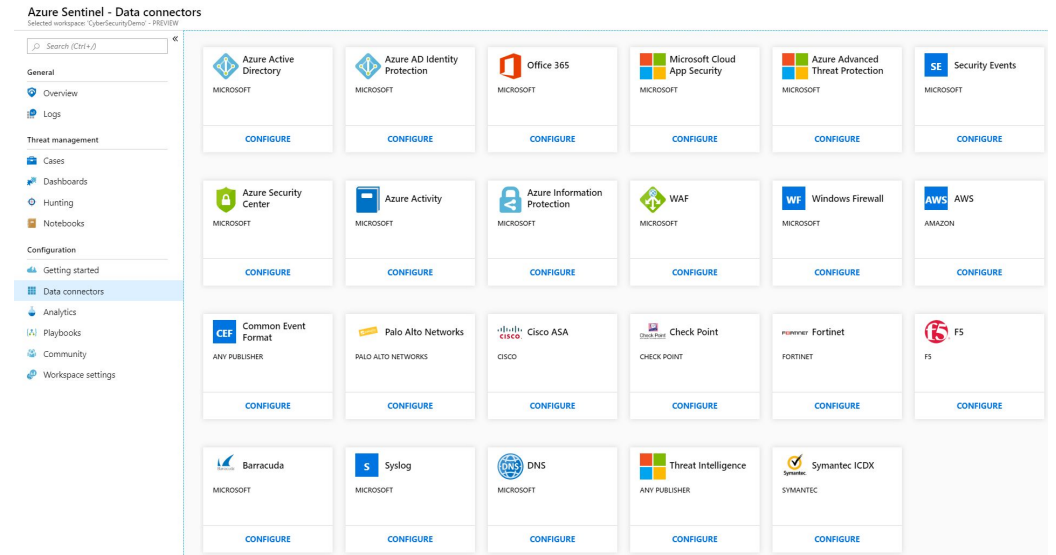
When it comes to Azure Sentinel there are also a number of disadvantages:

- Advanced hunting features require some advanced skills (Python, Jupyter and data science modules)
- Inability to bulk import detection rules, it's a highly manual process
- Cannot drill down from dashboards
- No available dashboards for Sysmon detections

Lab detection infrastructure – Azure Sentinel

Azure Sentinel doesn't offer the possibility to natively ingest Sysmon logs through out of the box data connectors. Sysmon log ingestion will have to be configured through three steps:

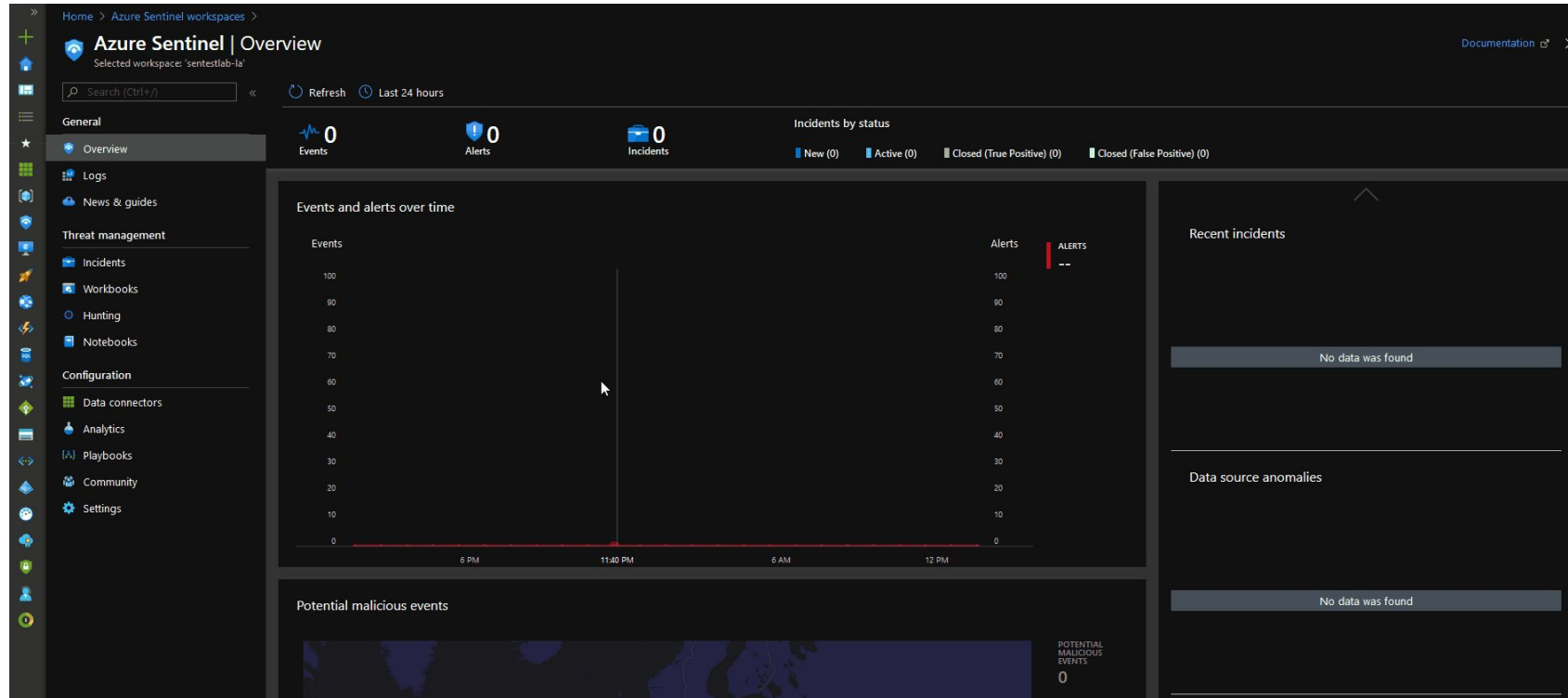
1. Activating Sysmon data collection
2. Installing Sysmon agents
3. Deploying a sysmon parser



Screenshot of Azure Sentinel data connector menu

Lab detection infrastructure – Azure Sentinel

Activating sysmon data collection used to require digging through Sentinel's workspace settings. To make matters worse the Sysmon/Operational log activation setting used to be hidden:



Lab detection infrastructure – Azure Sentinel

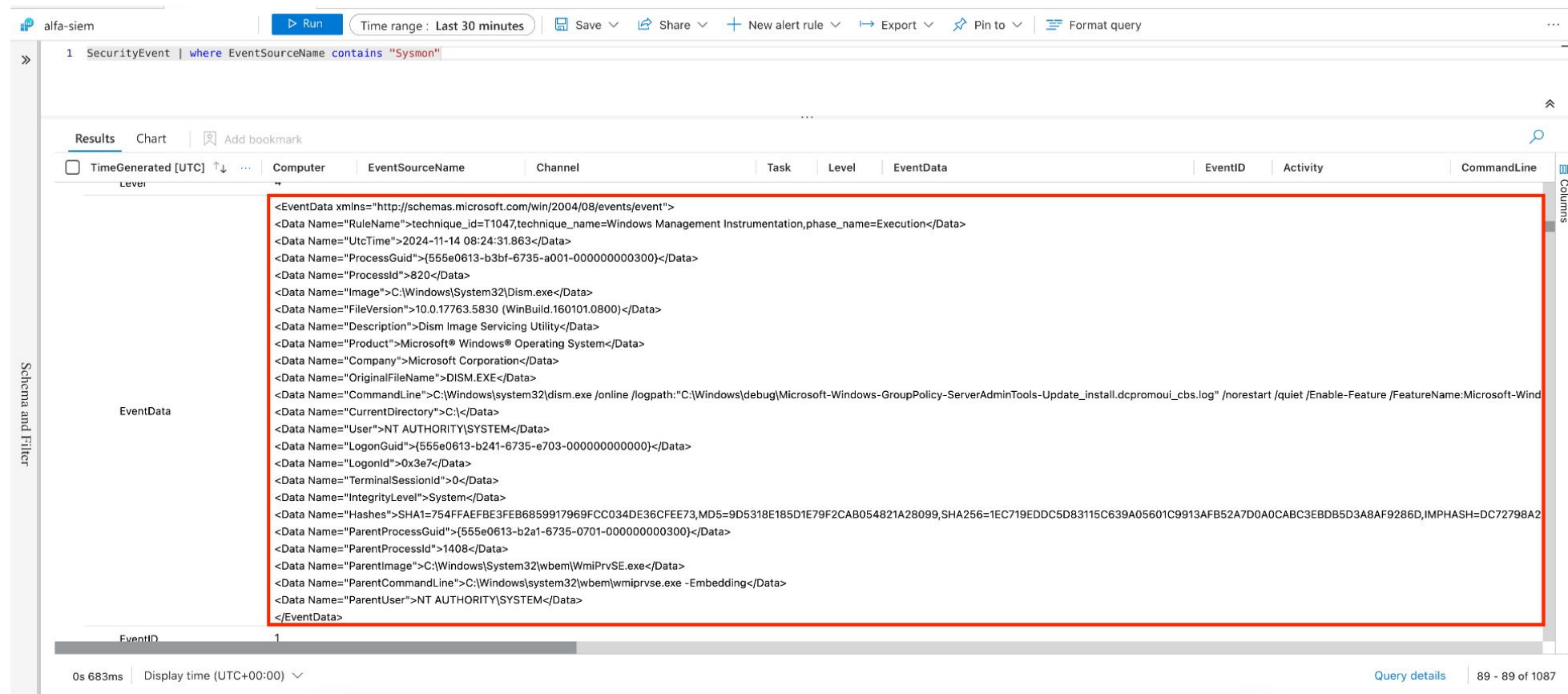
Activating sysmon data collection is now more straightforward thanks to Azure Monitoring Agents and Data Collection Rules. However, you still need to know how to find the right telemetry by using Bicep and XPath:

```
55 // Create Sysmon data collection rule
56 resource dcr 'Microsoft.Insights/dataCollectionRules@2021-04-01' = {
57   name: '${labname}-dcr'
58   location: location
59   kind: 'Windows'
60   tags: {
61     createdBy: 'Sentinel'
62   }
63   properties: {
64     dataFlows: [
65       {
66         destinations: [
67           '${labname}-siem'
68         ]
69         streams: [
70           'Microsoft-SecurityEvent'
71         ]
72       }
73     ]
74   }
75 }
```

```
74 dataSources: {
75   windowsEventLogs: [
76     {
77       name: 'WindowsSecurityLogs'
78       streams: [
79         'Microsoft-SecurityEvent'
80       ]
81       xpathQueries: [
82         'Microsoft-Windows-Sysmon/Operational!*'
83       ]
84     }
85   ]
86 }
87 description: 'Data collection rule to collect common Windows security events.'
88 destinations: {
89   logAnalytics: [
90     {
91       name: '${labname}-siem'
92       workspaceResourceId: workspace.outputs.workspaceResourceId
93     }
94   ]
95 }
96 }
97 }
```

Lab detection infrastructure – Azure Sentinel

By default Sysmon log data is unparsed and presented as XML, this makes interpretation of the data significantly harder without good knowledge of KQL, as seen in the example below:



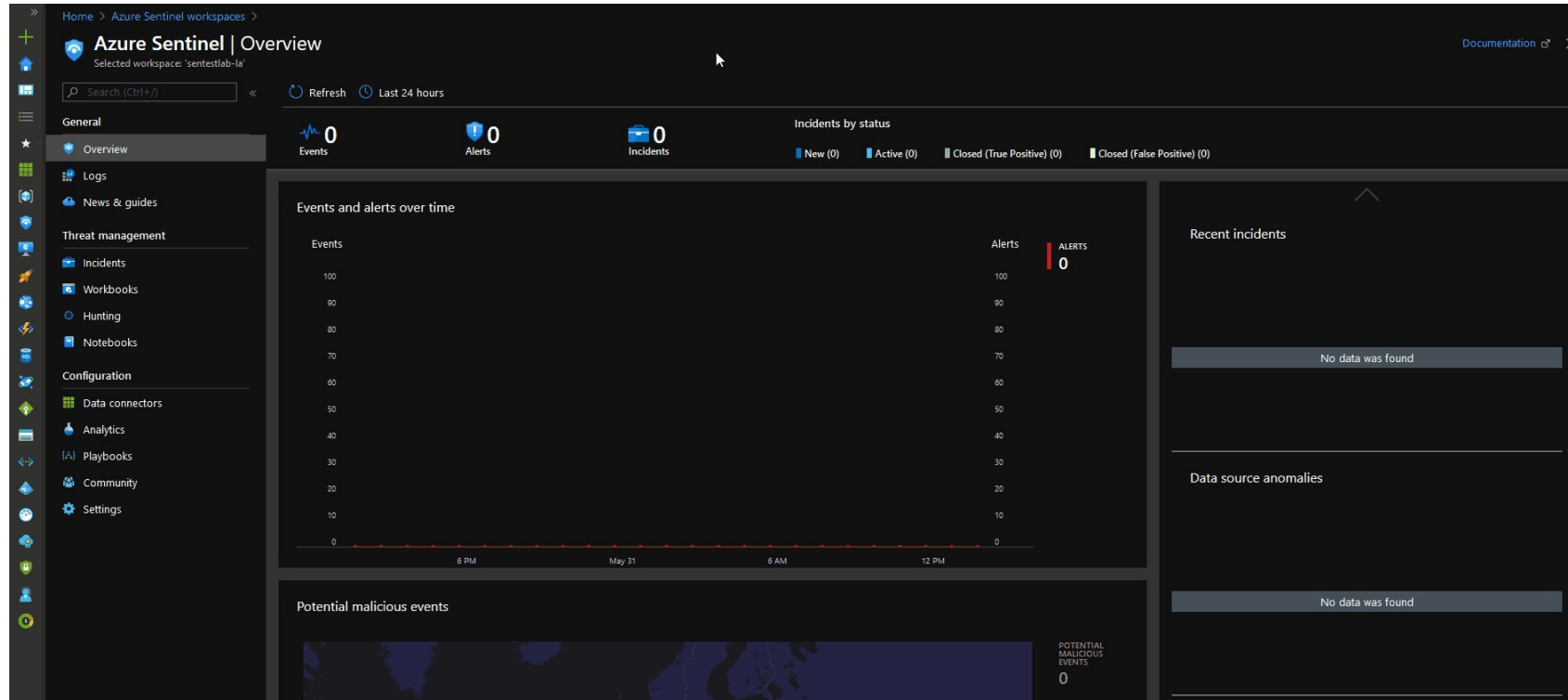
The screenshot shows the Azure Sentinel KQL query interface. The query is: `SecurityEvent | where EventSourceName contains 'Sysmon'`. The results are displayed in a table with columns: TimeGenerated [UTC], Computer, EventSourceName, Channel, Task, Level, EventData, EventID, Activity, and CommandLine. The EventData column contains a large XML block representing a Sysmon event.

```
<EventData xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <Data Name="RuleName">technique_id=T1047,technique_name=Windows Management Instrumentation,phase_name=Execution</Data>
  <Data Name="UtcTime">2024-11-14 08:24:31.863</Data>
  <Data Name="ProcessGuid">{555e0613-b3bf-6735-a001-000000000300}</Data>
  <Data Name="ProcessId">820</Data>
  <Data Name="Image">C:\Windows\System32\Dism.exe</Data>
  <Data Name="FileVersion">10.0.17763.5830 (WinBuild.160101.0800)</Data>
  <Data Name="Description">Dism Image Servicing Utility</Data>
  <Data Name="Product">Microsoft® Windows® Operating System</Data>
  <Data Name="Company">Microsoft Corporation</Data>
  <Data Name="OriginalFileName">DISM.EXE</Data>
  <Data Name="CommandLine">C:\Windows\system32\dism.exe /online /logpath:"C:\Windows\debug\Microsoft-Windows-GroupPolicy-ServerAdminTools-Update_install.dcpromoui_cbs.log" /norestart /quiet /Enable-Feature /FeatureName:Microsoft-Wind
  <Data Name="CurrentDirectory">C:\</Data>
  <Data Name="User">NT AUTHORITY\SYSTEM</Data>
  <Data Name="LogonGuid">{555e0613-b241-6735-e703-000000000000}</Data>
  <Data Name="LogonId">0x3e7</Data>
  <Data Name="TerminalSessionId">0</Data>
  <Data Name="IntegrityLevel">System</Data>
  <Data Name="Hashes">SHA1=754FFAEFBE3FEB6859917969FCC034DE36CFEE73,MD5=9D5318E185D1E79F2CAB054821A28099,SHA256=1EC719EDDC5D83115C639A05601C9913AFB52A7D0A0CABC3EBDB5D3A8AF9286D,IMPHASH=DC72798A2
  <Data Name="ParentProcessGuid">{555e0613-b2a1-6735-0701-000000000300}</Data>
  <Data Name="ParentProcessId">1408</Data>
  <Data Name="ParentImage">C:\Windows\System32\wbem\WmiPrivSE.exe</Data>
  <Data Name="ParentCommandLine">C:\Windows\system32\wbem\wmiprivse.exe -Embedding</Data>
  <Data Name="ParentUser">NT AUTHORITY\SYSTEM</Data>
</EventData>
```

The interface also shows a sidebar with 'Schema and Filter' and a bottom status bar indicating '0s 683ms | Display time (UTC+00:00) | Query details | 89 - 89 of 1087'.

Lab detection infrastructure – Azure Sentinel

Sentinel allows the possibility to write macro functions in KQL that can be stored within the platform and invoked on demand. Using this feature we can write a large function to automatically parse Sysmon data:



Lab detection infrastructure – Azure Sentinel

Without a parser analysts are forced to make complex queries that require advanced knowledge of KQL and to work with data that is nested and very hard to read, as seen in the screenshot below:

The screenshot shows the Azure Sentinel interface with a KQL query and its results. The query is as follows:

```
1 SecurityEvent
2 | where EventSourceName contains "Sysmon"
3 | where Task == 1
4 | extend d=parse_xml(EventData)
5 | where d.EventData.Data[4]["#text"] contains "cmd.exe"
```

The results table displays the following data:

TimeGenerated [UTC]	d	Computer	EventSourceName	Channel
	▼ Data 0 {"#text":"technique_id=T1059,technique_name=Command-Line Interface,phase_name=Execution",@"Name":"RuleName"} 1 {"#text":"2024-11-14T08:26:30.1230000Z",@"Name":"UtcTime"} 2 {"#text":"{555e0613-b436-6735-b600-000000000400",@"Name":"ProcessGuid"} 3 {"#text":"5680",@"Name":"ProcessId"} 4 {"#text":"C:\\Windows\\System32\\cmd.exe",@"Name":"Image"}			

Lab detection infrastructure – Azure Sentinel

Once the parser is installed analysts are able to execute very simple KQL statements as well as hunt using very clear and legible queries, as seen in the screenshot below:

The screenshot displays the Azure Sentinel KQL query interface. At the top, the workspace is named 'alfa-siem'. A blue 'Run' button is visible, along with a 'Time range : Last 30 minutes' selector. To the right are options for 'Save', 'Share', and 'New alert rule'. The query editor shows a KQL query:

```
1 Sysmon
2 | where process_command_line contains "cmd.exe"
```

Below the query editor, the 'Results' tab is active. The results are displayed in a table with the following columns: TimeGenerated [UTC] (with a sort icon), EventID, Computer, event_creation_time, and process_guid. The table contains one row of data:

TimeGenerated [UTC] ↑↓	EventID	Computer	event_creation_time	process_guid

On the left side of the table, there is a 'Schema and Filter' pane. On the right side, there is a 'Columns' pane. The table data is as follows:

file_description	Windows Command Processor
file_product	Microsoft® Windows® Operating System
file_company	Microsoft Corporation
file_name	Cmd.Exe
process_command_line	C:\Windows\system32\cmd.exe /c C:\Windows\system32\reg.exe query hklm\software\microsoft\windows\softwareinvento
file_directory	C:\Windows\system32\
user_name	NT AUTHORITY\SYSTEM
user_logon_guid	{555e0613-b3f5-6735-e703-000000000000}

Thank you for your attention